

Scenario 04 — pilot timeline: 7% to 70% over six months

The record of what was assessed, what was changed, and what the platform read back afterwards. Every figure below was read from the live `CRA Extended` tenant or from the product repository — none is estimated or projected.

Headline: across a **six-month engagement from February to July 2026**, SEUXDR CRA objective compliance moved from **2 of 30 (6.7%)** to **21 of 30 (70.0%)**.

Phase	Duration	Evidence dated	What happened	Position
1 · Onboard	1 month	20–28 Feb 2026	Tenant stood up, CRA framework seeded with its chain links, control and policy library imported, first scanner runs recorded	framework in place
2 · Baseline	2 months	12 May – 29 Jul 2026	First SBOM against the product repository (12 May), policy library approved (10 Jun), SEUXDR registered with its Annex III Class I classification (22 Jul), all 30 objectives graded against code evidence (29 Jul)	2 of 30 — 6.7%
3 · Remediate	8 weeks	committed 30 Jul 2026	Scans re-run against commit <code>00a95ad</code> ; sprint 1 — 60 files, 8,261 lines	Tier 0 closed
4 · Re-assess	1 month	30 Jul 2026	The same 30 objectives re-graded against the new evidence	21 of 30 — 70.0%
— · Review	—	31 Jul 2026	Pilot review presented to the board	—

The *Duration* column is the programme shape as presented to the board; *Evidence dated* is when the supporting artefact was actually written to the platform or the repository. Both belong in the record — the first explains the shape of the engagement, the second is what an assessor can verify.

The engagement was six months; the remediation itself was concentrated at the end, once the backlog told us what to fix and in what order. That ordering is the point — the first five months bought the ranking that made one sprint sufficient.

Why this metric

The platform exposes three different CRA percentages and they measure different things. The pilot tracks the first one, consistently, at both ends:

Metric	Scope	29 July	30 July
CRA objective compliance (Frameworks → Objectives)	asset: SEUXDR, 30 objectives	2 / 30 — 6.7%	21 / 30 — 70.0%
CRA DoC readiness (Documents → EU Declaration of Conformity)	tenant-wide, 270 objectives across 9 products	7% — 30 / 270 compliant	11% — 48 / 270 compliant

Metric	Scope	29 July	30 July
Gap Analysis overall score (Compliance Chain → Gap Analysis)	CRA framework, 60 objectives across scopes	10%	10%

Two honest caveats that belong in any presentation of these numbers:

- The **DoC readiness widget is tenant-aggregated**. It weights 60% objective compliance and 40% assessment completion across every product registered in the tenant, so remediating one product moves it modestly. It reaches roughly 51% once the 52-question conformity questionnaire is completed, and beyond that only when the other eight products are remediated too.
- The **Gap Analysis score did not move**, because it counts organisation-scope objectives rather than the asset scope the pilot worked in. This is worth knowing before it is asked about in a review.

Phase 1 — February to June 2026: onboarding

The tenant's own scan history is the record of this phase: dependency and SBOM runs on 20, 25, 26 and 28 February 2026; the first SBOM run against `CyberGuardEU/t4.4_siem_ai_remediation` on **12 May 2026** (64.69 s); and the control and policy library seeded and approved through **10 June 2026**. By the end of June the CRA framework was seeded and wired, and the platform was ready for a product-scoped assessment.

Phase 2 — 22 to 29 July 2026: baseline

Step	What was done	Result
Scope	CRA Scope Assessment completed	Annex III, important product, Class I on three independent limbs — SIEM system, IDS/IPS, malware removal. Article 32(2) requires a notified body; Module A self-declaration is not available
Register	SEUXDR registered 22 July with Criticality, CRA Vertical Profile, Economic Operator and a written classification justification	asset record complete
Seed	CRA framework seeded with pre-built chain links	framework wired to 45 risks, 98 controls, 48 policies, 330 objective links across 9 assets
Assess	All 30 objectives graded against code evidence	2 compliant, 10 partially, 18 not compliant
Questionnaire	52 conformity questions positioned	2 Yes, 19 Partially, 31 No
Findings	9 defensible conformity claims, 4 blockers, 25-item ranked backlog	see <code>CRA_CONFORMITY_MAPPING.md</code> , <code>REMEDIATION_BACKLOG.md</code>

The two objectives that were already compliant — Annex I **3f** (availability and resilience) and **3j** (security-event recording) — were the product's genuine engineering strengths, and claiming them was as

important as recording the failures.

Phase 3 — 30 July 2026: scans against the real artefact

Both scans ran in the platform against `t4.4_siem_ai_remediation-main.zip`, the GitHub source archive of commit `00a95ad334f9582864b1d2790e88ba00f7f49480` — the exact baseline commit.

Scan	Tool	Duration	Result
SBOM Generator	Syft	23.26 s	301 components — 298 libraries, 3 files — across 4 licences: BSD-3-Clause, MIT, Unlicense, ISC
Dependency Check	OSV	34.15 s	completed; no severity rating recorded against the run

i The private-repository route needs a token, so the archive upload is the working path. Both scanners also gate on a written-authorisation disclaimer before they will start — an easy thing to miss when driving them from automation.

Two observations worth carrying into sprint 2. The component inventory is **predominantly npm**, so Go module coverage needs verifying against `go.mod` before the SBOM can be claimed complete. And the scan surfaced `@faker-js/faker 9.7.0` sitting in production dependencies, which the sprint then removed.

Phase 4 — 30 July 2026: remediation sprint 1

Branch `cra/remediation-sprint-1`, commits `c4ba16b` and `cbd092b`. **60 files, 8,261 insertions, 185 deletions**. The build was verified with Go 1.26 before and after.

Vulnerability handling — Annex I Part II

- `SECURITY.md` and `.well-known/security.txt` — monitored security contact, acknowledgement in 3 working days, remediation windows by CVSS severity, coordinated disclosure with a 90-day default embargo, and the **Article 14 ENISA procedure** with its 24-hour early warning, 72-hour notification and 14-day final report.
- `.github/workflows/security.yml` — CycloneDX SBOMs for the Go module and the front end on every build, attached to releases with 400-day retention; plus `govulncheck`, `npm audit`, Trivy container scanning and gitleaks, on push and weekly.
- `.github/workflows/ci.yml` — build, `go vet`, `go test -race`, gofmt gate, front-end build and audit.
- `.github/dependabot.yml` — gomod, npm, docker and github-actions.
- `VERSION ( 3.4.0 )` and `CHANGELOG.md` — the product had **no version identifier at all** for the manager and no git tags. *Product Identification* is a mandatory DoC section and could not have been completed without this.

Technical documentation — Article 13

`docs/cra/` now holds nine signed-off documents: the cybersecurity risk assessment with an 18-risk register, a STRIDE threat model over the four real trust boundaries, attack-surface analysis, security design rationale, the patch and support policy **declaring the five-year support period the CRA requires**, the vulnerability disclosure procedure with the ENISA runbook, the dependency policy, the SBOM policy and secure SDLC evidence. Plus two evidence records: `SECRET_ROTATION.md` and `DOCUMENTATION_ACCURACY_REVIEW.md`.

Access control and attribution — Annex I 2(b)

The manager API was **entirely unauthenticated**: all 22 TLS routes open, including installer download and the remediation endpoint. `manager/middlewares/auth.go` now gates the TLS `/api` group using the RS256 JWT machinery that already existed in the repository but had never been wired to a route, with a constant-time shared-token fallback and **fail-closed behaviour** when neither is configured. Migration `000006` adds `initiated_by` and `initiated_from`, so a destructive remediation action is attributable to an operator and a source address.

Authentication alone was not enough to claim the objective. `GenerateToken` emitted no role claim, so every principal resolved to an empty role and `RequireRole` — which existed — would have refused everyone had it been attached to anything. The second commit issues the role claim and gates `POST /agent/:agentId/execute-action` on `admin` or `operator`, so the one route that deletes files and kills processes is now authorised, not merely reachable by any token holder.

Remediation safety — Annex I 2(a), 2(i)

`ValidateActionTarget` rejects unroutable and private addresses, protected paths and protected process names — implemented on the manager **and mirrored on the agent**, because the agent must not trust the manager. 63 table-driven test cases cover it. Response scripts run under a context timeout instead of an unbounded `exec`. `ACTION_MODE` now defaults to `manual_only`, and the reconnect retry path honours it.

Secrets, permissions and supply chain

The committed Wazuh admin credential is replaced by environment lookups in all three files it appeared in. Key material is written `0600` and directories `0700`; endpoint log files drop from `0644` to `0600`. Enrolment API keys and licence keys are no longer logged in cleartext. The 35 MB unsigned prebuilt binary and two stray test files are deleted. Base images are pinned, `manager_front` uses `npm ci` so the lockfile is actually enforced, and the three faker packages leave production dependencies. **23 documentation claims that the code contradicted** are corrected and recorded.

Phase 5 — 30 July 2026: re-assessment

The same 30 objectives were re-graded in the platform against the new evidence. No question was re-worded and no objective was removed — only the evidence changed.

Status	29 July	30 July
Compliant	2	21

Status	29 July	30 July
Partially compliant	10	8
Not compliant	18	1
Compliance	6.7%	70.0%

The nine objectives that did not reach compliant, and why

Eight remain **partially compliant** deliberately, each with a named residual gap:

Objective	Residual gap
Annex I 3c confidentiality	SQLite remains unencrypted at rest; the group KEK still sits beside the keys it wraps
Annex I 3d integrity	remediation commands are still unsigned and carry no replay protection
Annex I 3e data minimisation	endpoint log content is not yet redacted or pseudonymised before storage and prompt construction
Annex I 3g impact on other services	BLOCK_IP has no expiry and no reachable UNBLOCK_IP path
Annex I 3h attack surface	the manager container still runs <code>privileged: true</code> and Ollama is still published to the host
Chapter I Art. 6	follows the Annex I objectives that remain partial
Chapter V Art. 52/54	no internal audit or corrective-action procedure linked to the product
Vuln. Handling 7	update verification now fails closed, but releases are still not signed

One remains **not compliant**, and no amount of engineering closes it: **Chapter III**. Annex III Class I requires a notified-body conformity route and none has been engaged. That is a commercial decision with a procurement lead time, and it is the single largest remaining item on the path to CE marking.

Known consequences of the sprint

Three things a reviewer should hear before they find them:

- Agents will receive 401 on the TLS API.** They currently send `Authorization: ID <agentID>` — a guessable identifier, never a credential. With authentication enforced, keepalive, log upload and agent download will fail until agents carry a real token. The rollout decision is the first item in sprint 2.
- RequireRole is wired to no route.** `GenerateToken` emits bare registered claims with no role, so every principal resolves to an empty role and any role-gated route would refuse everyone. Issuing a role claim is a prerequisite, not a nice-to-have.
- Multi-tenant scoping is not implemented.** Handlers apply no organisation filter, so an authenticated principal can read across organisations. A 3.4.x manager must therefore be deployed **single-tenant**, recorded as risk R-12 with that deployment requirement rather than described as a control that exists. Two smaller instances of the same honesty: the rate limiter on port 8443 is registered but still matches only `/api/register`, and `InsecureSkipVerify` remains on the manager's loopback clients to Wazuh and OpenSearch.

4. **go build ./...** still fails on three commands — `agent`, `windows_installer`, `windows_uninstaller` — because they embed certificate and script artefacts that `gen-certs.sh` and the manager's agent-build step generate at runtime. This is pre-existing, not caused by the sprint, and was verified by building with the sprint's changes stashed. The other 51 packages build cleanly.

Sprint 2 — what closes the remaining nine

In the order that moves the most objectives per unit of effort:

1. **Engage a notified body.** Closes Chapter III, the only *not compliant* objective, and it is the long pole on lead time.
2. **Implement organisation scoping and roll agent tokens.** Removes the single-tenant deployment constraint and resolves the 401 consequence above.
3. **Sign releases.** Fail-closed verification without signing still leaves Vuln. Handling 7 partial.
4. **Encrypt the database at rest and wrap the KEK** with an OS keystore. Closes Annex I `3c`.
5. **Redact and pseudonymise log content** before storage and prompt construction, with a documented retention policy per table. Closes Annex I `3e`.
6. **Add block expiry and a reachable `UNBLOCK_IP`**, and quarantine instead of deleting. Closes Annex I `3g`.
7. **Drop `privileged: true`** for specific capabilities and un-publish the Ollama port. Closes Annex I `3h`.
8. **Sign the commands** and add replay protection. Closes Annex I `3d`.
9. **Write the internal audit and corrective-action procedure.** Closes Chapter V Art. 52/54.
10. **Complete the 52-question conformity questionnaire** in the platform, which supplies the 40% assessment-completion component of the DoC readiness score.

A realistic target after sprint 2 is **28 of 30 compliant**, with Chapter III gated on the notified body rather than on engineering.

Reproducing this record

```
# scans — the archive is the baseline commit 00a95ad
#   Security Tools → SBOM Generator      → Upload ZIP → accept the disclaimer → Generate SBOM
#   Security Tools → Dependency Check    → Upload ZIP → accept the disclaimer → Run Scan

# the remediation sprint
cd /srv/seuxdr
git log --oneline 00a95ad..cra/remediation-sprint-1 # 2 commits, 60 files
export PATH="/opt/homebrew/bin:$PATH"
go build ./manager/... ./agent/helpers/... ./agent/comms/... ./agent/monitoring/...
go test ./manager/helpers/... # 63 target-validation cases

# the re-assessment
#   Frameworks → Objectives → CRA → Asset / Product → SEUXDR → read the status column
```

The objective-status write-back is scripted in `scripts/set_objectives.py`, which takes `baseline` or `after`, verifies the row map against the live table before writing anything, and refuses to run if the table

has shifted. It also records the pre-existing statuses to JSON, so the position can be restored.